

Modify Authentication Process

Sub-techniques (9)



Adversaries may modify authentication mechanisms and processes to access user credentials or enable otherwise unwarranted access to accounts. The authentication process is handled by mechanisms, such as the Local Security Authentication Server (LSASS) process and the Security Accounts Manager (SAM) on Windows, pluggable authentication modules (PAM) on Unix-based systems, and authorization plugins on MacOS systems, responsible for gathering, storing, and validating credentials. By modifying an authentication process, an adversary may be able to authenticate to a service or system without using [Valid Accounts](#).

Adversaries may maliciously modify a part of this process to either reveal credentials or bypass authentication mechanisms. Compromised credentials or access may be used to bypass access controls placed on various resources on systems within the network and may even be used for persistent access to remote systems and externally available services, such as VPNs, Outlook Web Access and remote desktop.

ID: T1556

Sub-techniques: [T1556.001](#), [T1556.002](#), [T1556.003](#), [T1556.004](#), [T1556.005](#), [T1556.006](#), [T1556.007](#), [T1556.008](#), [T1556.009](#)

- ① **Tactics:** [Defense Impairment](#), [Persistence](#), [Credential Access](#)
- ① **Platforms:** IaaS, Identity Provider, Linux, Network Devices, Office Suite, SaaS, Windows, macOS

Contributors: Chris Ross @xorrior

Version: 3.0

Created: 11 February 2020

Last Modified: 12 May 2026

[Version Permalink](#)

Procedure Examples

ID	Name	Description
C0046	ArcaneDoor	ArcaneDoor included modification of the AAA process to bypass authentication mechanisms. ^[1]
S9013	DRYHOOK	DRYHOOK has intercepted and logged user credentials by modifying the Perl module in Ivanti Connect Secure VPN edge-devices located within <code>/home/perl/DSAuth.pm</code> . ^{[2][3]}
S0377	Ebury	Ebury can intercept private keys using a trojanized <code>ssh-add</code> function. ^[4]
G1016	FIN13	FIN13 has replaced legitimate KeePass binaries with trojanized versions to collect passwords from numerous applications. ^[5]
S0487	Kessel	Kessel has trojanized the <code>ssh_login</code> and <code>user-auth_pubkey</code> functions to steal plaintext credentials. ^[6]
S0692	SILENTRINITY	SILENTRINITY can create a backdoor in KeePass using a malicious config file and in TortoiseSVN using a registry hook. ^[7]

Mitigations

ID	Mitigation	Description
M1047	Audit	Review authentication logs to ensure that mechanisms such as enforcement of MFA are functioning as intended. Periodically review the hybrid identity solution in use for any discrepancies. For example, review all Pass Through Authentication (PTA) agents in the Azure Management Portal to identify any unwanted or unapproved ones.^[8] If ADFS is in use, review DLLs and executable files in the AD FS and Global Assembly Cache directories to ensure that they are signed by Microsoft. Note that in some cases binaries may be catalog-signed, which may cause the file to appear unsigned when viewing file properties.^[9] Periodically review for new and unknown network provider DLLs within the Registry (<code>HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\<NetworkProviderName>\NetworkProvider\ProviderPath</code>). Ensure only valid network provider DLLs are registered. The name of these can be found in the Registry key at <code>HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\NetworkProvider\Order</code>, and have corresponding service subkey pointing to a DLL at <code>HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\<NetworkProviderName>\NetworkProvider</code>.
M1032	Multi-factor Authentication	Integrating multi-factor authentication (MFA) as part of organizational policy can greatly reduce the risk of an adversary gaining control of valid credentials that may be used for additional tactics such as initial access, lateral movement, and collecting information. MFA can also be used to restrict access to cloud resources and APIs.
M1028	Operating System Configuration	Ensure only valid password filters are registered. Filter DLLs must be present in Windows installation directory (<code>C:\Windows\System32</code> by default) of a domain controller and/or local computer with a corresponding entry in <code>HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa\Notification Packages</code>. Starting in Windows 11 22H2, the <code>EnableMPRNotifications</code> policy can be disabled through Group Policy or through a configuration service provider to prevent Winlogon from sending credentials to network providers.^[10]
M1027	Password Policies	Ensure that <code>AllowReversiblePasswordEncryption</code> property is set to disabled unless there are application requirements.^[11]
M1026	Privileged Account Management	Audit domain and local accounts as well as their permission levels routinely to look for situations that could allow an adversary to gain wide access by obtaining credentials of a privileged account. ^[12] ^[13] These audits should also include if default accounts have been enabled, or if new local accounts are created that have not be authorized. Follow best practices for design and administration of an enterprise network to limit privileged account use across administrative tiers. ^[14] Limit access to the root account and prevent users from modifying protected components through proper privilege separation (ex SELinux, grsecurity, AppArmor, etc.) and limiting Privilege Escalation opportunities. Limit on-premises accounts with access to the hybrid identity solution in place. For example, limit Azure AD Global Administrator accounts to only those required, and ensure that these are dedicated cloud-only accounts rather than hybrid ones.^[9]
M1025	Privileged Process Integrity	Enabled features, such as Protected Process Light (PPL), for LSA.^[15]
M1022	Restrict File and Directory Permissions	Restrict write access to the <code>/Library/Security/SecurityAgentPlugins</code> directory.
M1024	Restrict Registry Permissions	Restrict Registry permissions to disallow the modification of sensitive Registry keys such as <code>HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\NetworkProvider\Order</code>.
M1018	User Account	Ensure that proper policies are implemented to dictate the the secure enrollment and deactivation of

Detection Strategy

ID	Name	Analytic ID	Analytic Description
DET0104	Detect Modification of Authentication Processes Across Platforms	AN0287	Detects modification of LSASS and authentication DLLs, suspicious registry changes to password filter packages, and abnormal process access to lsass.exe. Correlates registry modifications, DLL loads, and process handle access events.
		AN0288	Detects modification of PAM configuration files, unauthorized new PAM modules, and suspicious process execution accessing PAM-related binaries. Correlates file modification events in /etc/pam.d/ with process execution of unauthorized binaries.
		AN0289	Detects unauthorized additions or changes to /Library/Security/SecurityAgentPlugins and suspicious process activity attempting to hook authentication APIs. Correlates file modifications with abnormal plugin loads in authentication flows.
		AN0290	Detects suspicious configuration changes in IdP authentication flows such as enabling reversible password encryption, MFA bypass, or policy weakening. Correlates policy modification events with unusual administrative activity.
		AN0291	Detects unauthorized changes to IAM authentication configurations such as disabling MFA, creating backdoor access keys, or altering trust policies. Correlates identity policy updates with unusual login behavior.

References

1. [Cisco Talos. \(2024, April 24\). ArcaneDoor - New espionage-focused campaign found targeting perimeter network devices. Retrieved January 6, 2025.](#)

2. [John Wolfram, Josh Murchie, Matt Lin, Daniel Ainsworth, Robert Wallace, Dimiter Andonov, Dhanesh Kizhakkinan, Jacob Thompson. \(2025, January 8\). Ivanti Connect Secure VPN Targeted in New Zero-Day Exploitation. Retrieved April 14, 2026.](#)

3. [Sila Ozeren Hacioglu. \(2025, May 5\). UNC5221's Latest Exploit: Weaponizing CVE-2025-22457 in Ivanti Connect Secure. Retrieved April 13, 2026.](#)

4. [M.Léveillé, M.. \(2014, February 21\). An In-depth Analysis of Linux/Ebury. Retrieved April 19, 2019.](#)

5. [Ta, V., et al. \(2022, August 8\). FIN13: A Cybercriminal Threat Actor Focused on Mexico. Retrieved February 9, 2023.](#)

6. [Dumont, R., M.Léveillé, M., Porcher, H. \(2018, December 1\). THE DARK SIDE OF THE FORSSHE A landscape of OpenSSH backdoors. Retrieved July 16, 2020.](#)

7. [Salvati, M. \(2019, August 6\). SILENTTRINITY Modules. Retrieved March 24, 2022.](#)

8. [Mike Burns. \(2020, September 30\). Detecting Microsoft 365 and Azure Active Directory Backdoors. Retrieved September 28, 2022.](#)

9. [Microsoft Threat Intelligence Center, Microsoft Detection and Response Team, Microsoft 365 Defender Research Team . \(2022, August 24\). MagicWeb: NOBELIUM's post-compromise trick to authenticate as anyone. Retrieved September 28, 2022.](#)

10. [Microsoft. \(2023, January 26\). Policy CSP - WindowsLogon. Retrieved March 30, 2023.](#)

11. [Microsoft. \(2021, October 28\). Store passwords using reversible encryption. Retrieved January 3, 2022.](#)

12. [Microsoft. \(2016, April 15\). Attractive Accounts for Credential Theft. Retrieved June 3, 2016.](#)

13. [Microsoft. \(2016, April 16\). Implementing Least-Privilege Administrative Models. Retrieved June 3, 2016.](#)

14. [Plett, C., Poggemeyer, L. \(12, October 26\). Securing Privileged Access Reference Material. Retrieved April 25, 2017.](#)

15. [Microsoft. \(2013, July 31\). Configuring Additional LSA Protection. Retrieved February 13, 2015.](#)